Discovering the Hidden Score Board in OWASP Juice Shop

This lab focuses on web content discovery and application reconnaissance using DIRB, dirsearch, and OWASP ZAP to identify a hidden Score Board page in the intentionally vulnerable OWASP Juice Shop application.

Below is documentation-ready text for your GitHub PDF. Keep the results aligned with what you actually observed in your lab.

1. Objective

To identify a hidden application page by discovering accessible paths and analyzing the application's exposed routes using web content discovery tools.

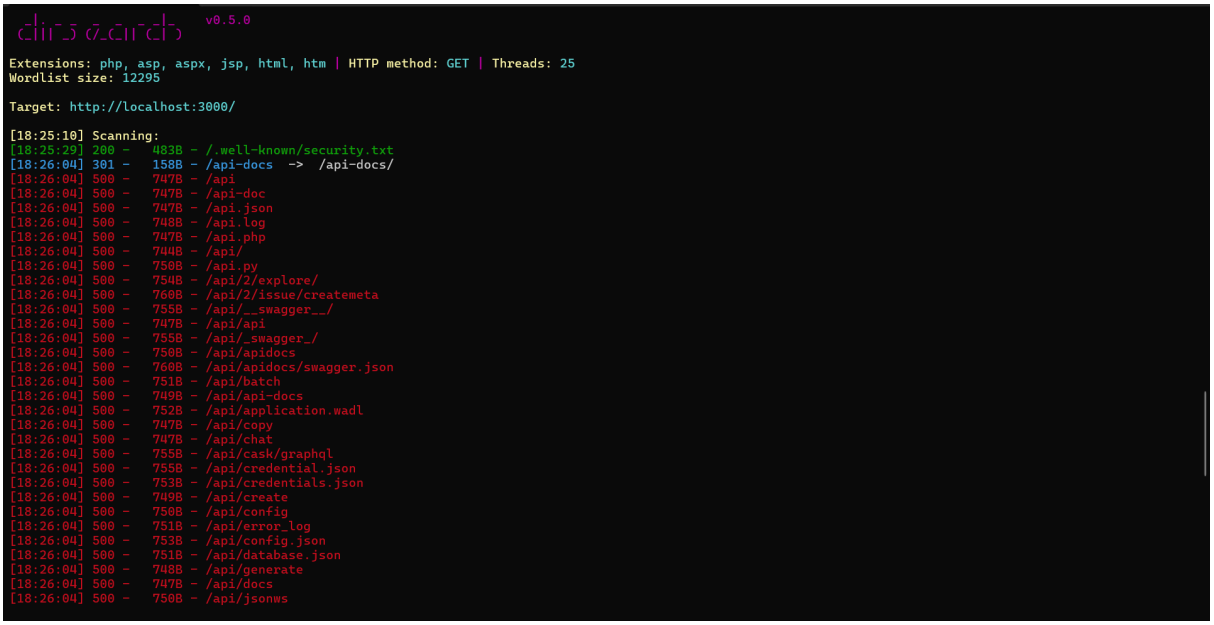
2. Tools Used

- **DIRB** — directory and web-path discovery.
- **Dirsearch** — web path and resource enumeration.
- **OWASP ZAP** — web application analysis, including reviewing discovered URLs and crawling results.

3. Methodology — How I Solved the Lab

Step 1: Identify the target application
Confirmed that OWASP Juice Shop was running locally at http://localhost:3000/ and opened the application in a browser.

Step 2: Enumerate web paths using dirsearch
Used dirsearch to conduct a second path-discovery check and compare the results with the DIRB scan.
Command:- dirsearch -u http://localhost:3000/
Reviewed the discovered paths and considered whether the application exposed routes that were not visible during normal browsing.



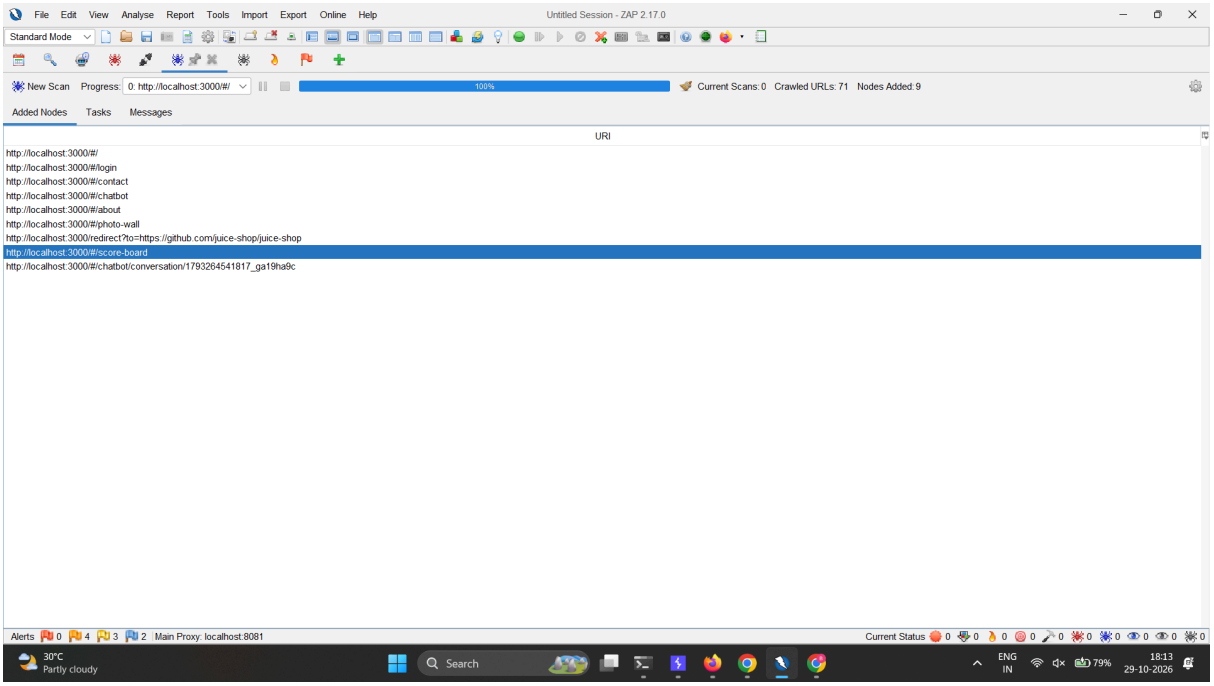
```
[18:26:05] 500 -   755B - /api/swagger/ui/index
[18:26:05] 500 -   756B - /api/swagger/swagger
[18:26:05] 500 -   749B - /api/delete
[18:26:05] 500 -   759B - /api/spec/swagger.json
[18:26:05] 500 -   755B - /api/swagger.json
[18:26:05] 500 -   753B - /api/users.json
[18:26:05] 500 -   747B - /api/show
[18:26:05] 500 -   750B - /api/user.json
[18:26:05] 500 -   753B - /api/timelion/run
[18:26:05] 500 -   749B - /api/ps
[18:26:05] 500 -   747B - /api/tags
[18:26:05] 500 -   754B - /api/swagger.yml
[18:26:05] 500 -   751B - /api/v1
[18:26:05] 500 -   755B - /api/swagger.yaml
[18:26:05] 500 -   749B - /api/v1/
[18:26:05] 500 -   760B - /api/v1/swagger.json
[18:26:05] 500 -   748B - /api/v2/
[18:26:05] 500 -   750B - /api/v2
[18:26:05] 500 -   761B - /api/v1/swagger.yaml
[18:26:05] 500 -   750B - /api/v3
[18:26:05] 500 -   761B - /api/v2/helpdesk/discover
[18:26:05] 500 -   759B - /api/v2/swagger.json
[18:26:05] 500 -   750B - /api/v4
[18:26:05] 500 -   756B - /api/vendor/phpunit/phpunit/phpunit
[18:26:05] 500 -   760B - /api/v2/swagger.yaml
[18:26:05] 500 -   748B - /apibuild.pyc
[18:26:05] 500 -   750B - /api/version
[18:26:05] 500 -   749B - /apidoc
[18:26:05] 500 -   750B - /api/whoami
[18:26:05] 500 -   747B - /apidocs
[18:26:05] 500 -   758B - /apiserver-aggregator-ca.cert
[18:26:05] 500 -   758B - /apiserver-aggregator.cert
[18:26:05] 500 -   754B - /apiserver-key.pem
[18:26:05] 500 -   744B - /apis
[18:26:05] 500 -   759B - /apiserver-aggregator.key
[18:26:05] 500 -   756B - /apiserver-client.crt
[18:26:08] 301 -   156B - /assets  ->  /assets/

Too many request errors

Task Completed
```

Step 3: Analyze the application using OWASP ZAP

Configured OWASP ZAP to inspect the local Juice Shop application. Used its crawling and site-mapping features to review discovered resources and investigate application routes. For a JavaScript-heavy application, browser-based or AJAX crawling can be useful for discovering client-side navigation.



Step 4: Perform directory discovery using DIRB

Executed a directory scan against the authorized local application to identify potentially accessible directories and resources.

Command:- dirb http://localhost:3000/

Reviewed the scan output for interesting paths and resources that were not directly linked from the application's main interface.

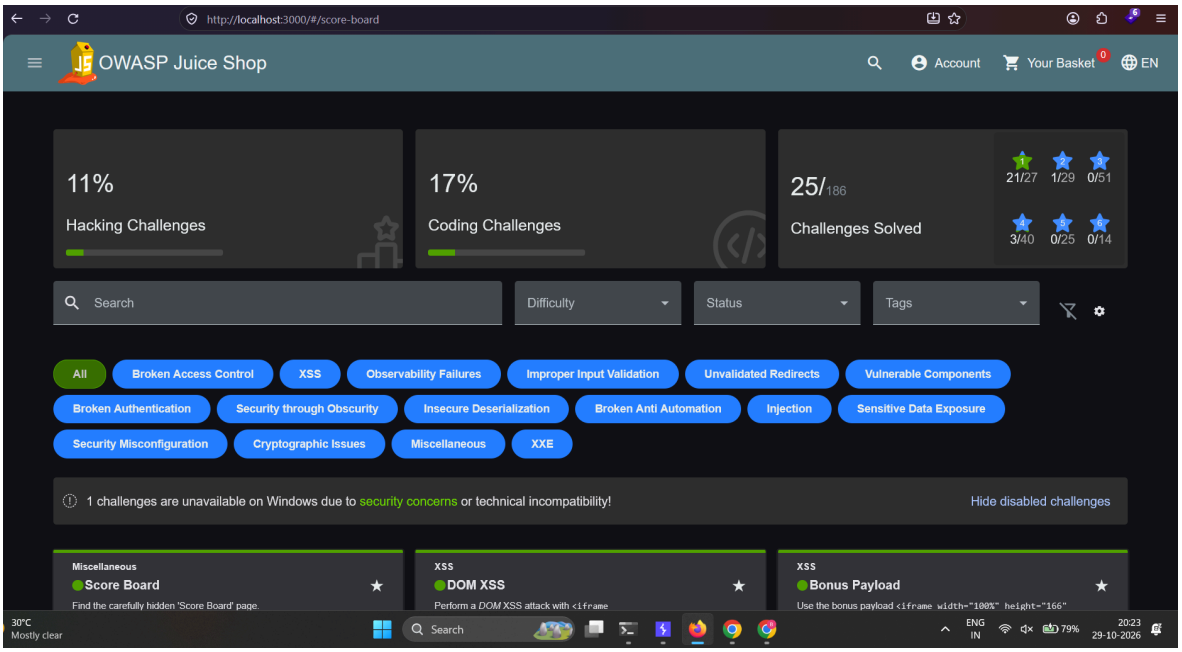
Step 5: Locate and verify the Score Board

Investigated the hidden route and opened:

http://localhost:3000/#/score-board

Verified that the Score Board page loaded successfully and displayed the available Juice Shop challenges.

The official Juice Shop documentation identifies this as the “Score Board” challenge, which involves locating a page that is deliberately hidden from normal application navigation.
Pwning OWASP Juice Shop+1



Technical note: The # fragment in this URL is handled by the browser-side application and is not sent to the server as part of the HTTP request. Therefore, conventional directory scanners may not discover the client-side route directly; their findings should be documented separately from the route verification.

4. Security Impact — How Could This Expose Information?

- Discovering a hidden route demonstrates how an attacker can identify application functionality that is not immediately visible through the user interface.
- In a real-world application, route discovery could reveal administrative pages, internal functionality, or links to sensitive information if those resources lack proper authorization controls.
- For this lab, however, finding the Score Board does not itself demonstrate a sensitive-data disclosure vulnerability. The Score Board is an intended training feature that lists challenges and their status.
- Pwning OWASP Juice Shop

5. Remediation and Security Recommendations

- **Enforce server-side authorization:** Verify user permissions for every protected resource and API endpoint.
- **Do not rely on hidden URLs:** Removing links from the interface or obscuring route names is not a substitute for access control.
- **Review application routes:** Identify unintended exposure of sensitive or administrative functionality.
- **Minimize information disclosure:** Avoid exposing internal details, sensitive records, or unnecessary application metadata to unauthorized users.
- **Retest access controls:** Attempt to access protected functionality with an unauthorized account to verify that the server denies the request.

6. Result

Successfully located and accessed the hidden Score Board in the OWASP Juice Shop lab. This exercise improved my understanding of directory enumeration, web application crawling, route discovery, and the importance of enforcing

authorization independently of URL visibility.

Severity Classification: Informational — Hidden Route Discovery. The severity may range from Low to High, depending on evidence of unauthorized access, the sensitivity of the exposed data, and the potential impact of the information disclosure. For this lab the severity is **Low.**

Reference: Official OWASP Juice Shop — Finding the Score Board